CRA-related standards

Status from 30 September

OpenSSF

OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Introduction

CRA Standardization request

EUROPEAN
COMMISSION

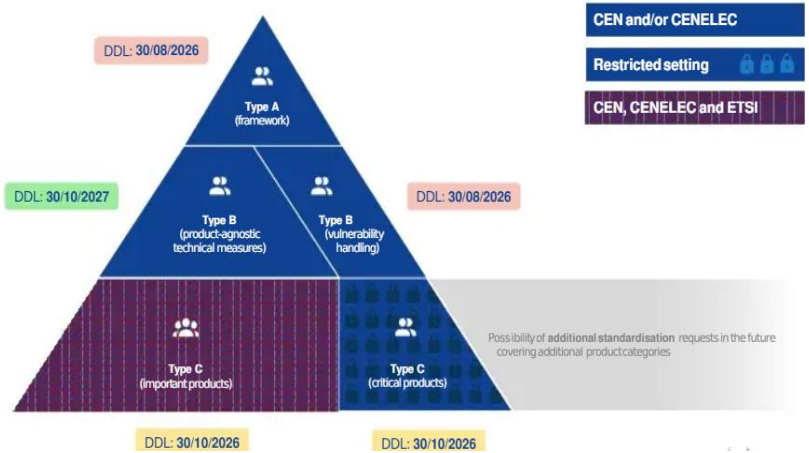
Brussels, 3.2.2025
C(2025) 618 final

COMMISSION IMPLEMENTING DECISION

of 3.2.2025

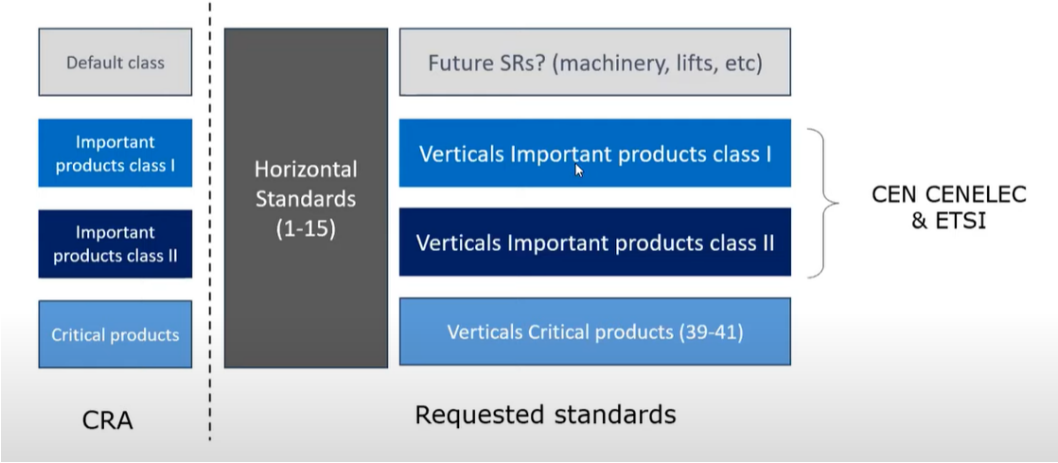
on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)

https://ec.europa.eu/transparency/documents-register/detail?ref=C(2025)618&lang=en
https://cyberstand.eu/sites/default/files/2025-02/Filipe%20Slides%20CRA_implementation_Feb-2025.pdf



Horizontal standards (1-15)	Vertical standards (16-41)
• Risk-based approach (CRA Annex I) • Essential Requirements (CRA Annex I part 1) • Vulnerability Handling (CRA Annex I part 2)	• Important products class 1 (CRA Annex III) • Important products class 2 (CRA Annex III) • Critical products (CRA Annex IV)

CRA Standardization request



41 topics

3 ‘types’ of deliverables:

Category “A”: horizontal framework	Category “B”: product-agnostic technical measures & vulnerability handling	Category “C”: Important and critical products CRA Standardization Request 9 April 2025 36
• Only CEN and CENELEC • Topic #1 (JTC 13 WG9) • deadline 2026-08-30	• Only CEN and CENELEC • Topic #2-15 (JTC 13 WG9) • Deadline 2027-10-30 (except for line 15 - vulnerability handling - 2026-08-30)	• Topic #16-38: CEN, CENELEC and ETSI • deadline 2026-10-30 • Topic #39-41:CEN and CENELEC • Critical products

A section of the CEN, CENELEC and ETSI WP

Version: V1
Date: 2025-04-02

CEN, CENELEC and ETSI Work Programme
M/604- Cyber Resilience Act

M/606	Technical Committee(s)		M/606 - Planning for standard development						
Topics M606 - Annex I	TC ref.	TC title	In collaboration with	Work Item	Standard reference	Standard title	Last realized stage	Deadline for adoption	Comment
Line 1: European standard(s) on designing, developing and producing products with digital elements in such a way that they ensure an appropriate level of cybersecurity based on the risks									
1	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013089	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements Principles for cyber resilience	10.99 - NWI - New Work Item adopted	2026/08/30	
Lines 2-14 - European standard(s) CRA essential requirements									
2 to 14	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013091	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Generic Security Requirements	10.99 - NWI - New Work Item adopted	2027/10/30	
Line 15: European standard(s) on vulnerability handling for products with digital elements									
15	CEN-CLC/JTC 13 WG 9	Cybersecurity and Data Protection	N/A	JT013090	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Cybersecurity requirements for products with digital elements – Vulnerability handling	10.99 - NWI - New Work Item adopted	2026/08/30	
Line 16: European standard(s) on essential cybersecurity requirements for identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers									
16	CEN/TC 224 WG 17	Personal identification and related personal devices with secure element, systems, operations and privacy in a multi sectorial environment	CEN/TC 224 WG 17 (including expertise from WG 18,19 and 20) TC ESI	002242XX	*EN xxxxxx (Will be be defined after the activation of the Work Item)*	Identity management systems and privileged access management software and hardware, including authentication and access control readers, including biometric readers : criteria to fulfill with the essential requirements from regulation 2024/2487 (CRA)	TC decision taken	2026/10/30	
Line 17: European standard(s) on essential cybersecurity requirements for standalone and embedded browsers									
17a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-1*	European standard(s) on essential cybersecurity requirements for embedded browsers	PWI - Proposed Work Item created	2026/10/30	
17b	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 617-2*	European standard(s) on essential cybersecurity requirements for standalone browsers	PWI - Proposed Work Item created	2026/10/30	
Line 18: European standard(s) on essential cybersecurity requirements for password managers									
18	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 618*	European standard(s) on essential cybersecurity requirements for password managers	PWI - Proposed Work Item created	2026/10/30	
Line 19: European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software									
19	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9	*(Will be be defined after the adoption of the Work Item)*	*EN 304 619*	European standard(s) on essential cybersecurity requirements for software that searches for, removes, or quarantines malicious software	PWI - Proposed Work Item created	2026/10/30	
Line 20: European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)									
20a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 620*	European standard(s) on essential cybersecurity requirements for products with digital elements with the function of virtual private network (VPN)	PWI - Proposed Work Item created	2026/10/30	
20b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81652	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for products with digital elements with the function of virtual private network (VPN)	00.60 - PWI - Preliminary Work Item created	2026/10/30	
Line 21: European standard(s) on essential cybersecurity requirements for network management systems									
21a	ETSI CYBER-EUSR	ETSI TC Cyber Working Group for EUSR	CEN-CLC/JTC 13 WG 9 CLC/TC 65X WG3 mode 2	*(Will be be defined after the adoption of the Work Item)*	*EN 304 621*	European standard(s) on essential cybersecurity requirements for network management systems	PWI - Proposed Work Item created	2026/10/30	
21b	CLC/TC 65X WG 3	Industrial-process measurement, control and automation	ETSI TC Cyber EUSR Mode 2	81650	*EN 62443-5-XX (Will be be defined after the activation of the Work Item)*	Security Profile for network management systems (based on IEC 62443)	00.60 - PWI - Preliminary Work Item created	2026/10/30	

Not complete

https://www.cencenelec.eu/media/CEN-CENELEC/News/Newsletters/2025/m_606_work_programme_final.pdf

WoW – CEN/CENELEC & ETSI Mode 4

TECHNICAL WORKING PROCEDURES, 21-23 January 2025

P ANNEX 3: ESO's rights and responsibilities in the different modes

	Mode 1	Mode 2	Mode 3	Mode 4	Mode 5**
Duty to keep other parties informed (Work Programme, agenda and meeting report)	YES	YES	YES	YES	YES
Attend relevant parts of Technical Body meetings*	NO	YES	YES	YES	YES
Right to intervene in debate	NO	NO	NO	YES	YES
Be subscribed to Technical Body lists	NO	YES	NO	YES	YES
Provide input documents for information to relevant Technical Body	NO	YES	YES	YES	YES
Get access rights to documents repositories	NO	YES	NO	YES	YES
Ability to share working documents received from the other Party with the represented ESO TB and its secretariat	NO	YES	NO	YES	YES
Submit contribution to draft deliverable(s)	NO	YES	YES	YES	YES
Right to formally approve documents	NO	NO	NO	NO	YES
Become Technical Body official (Chair/Secretary)	NO	NO	NO	NO	YES
Manage comments resolution processes	NO	NO	YES	NO	YES
** members of all co-operating ESOs will be entitled to participate.					

https://portal.etsi.org/directives/51_ETSI_directives_jun_2025.pdf

Mode 4 is enough for being properly involved in the works related to CRA

We continue to explore the possibility to become a liaison organization

Or to get involved via NBN

Standards developed under CEN/CENELEC

CEN/CENELEC Work Programme

Project Team 1

- **Cybersecurity requirements for products with digital elements – Principles for cyber resilience**
- WI number – JT013089
- CRA requirement Annex I, Part I, 1
- M/606 item 1, 30/08/2026
- Does not (directly) provide a presumption of conformity.
- Addressing the process activities for security risk management during the total product life cycle.
- Activities are described as:
  - Expected inputs
  - Requirement
  - Expected outputs
  - Assessment criteria
- As a horizontal framework standard, it will not mandate any specific methodologies.

Project team 2

- **Cybersecurity requirements for products with digital elements – Generic security requirements**
- WI number : JT013091
- CRA requirement Annex I, Part I, 2
- M/606 items 2-14, 30/10/2027
- Does not provide a presumption of conformity.
- Addressing the essential product requirements.
- Provides a library of security controls with their objectives and more technical assessment criteria.
- Provides a mapping of the essential requirements to these security controls.
- Builds upon the EN 18031:2024 series, augmented with additional security controls.

Project team 3

- **Cybersecurity requirements for products with digital elements – Vulnerability handling**
- WI number : JT013090
- CRA requirement Annex I, Part II
- M/606 item 15, 30/08/2026
- The only horizontal standard of the three that hopefully might be suited for citation to provide a partial presumption of conformity.
- Addressing the process activities for vulnerability handling.
- Perceived as a horizontal standard that the verticals should be able to normatively reference with no or minimal adoptions.
- Strong normative dependency on the SOTA standards EN ISO/IEC 30111 and 29147.

CEN/CENELEC JTC 13 WG9 Work Programme

Project 1

High level process **activities** to address the Total Product Life Cycle, defining:

- Goal that needs to be achieved
- Mandatory and optional inputs
- Minimum expected outcomes

Process activities such as security monitoring, risk assessment, verification, validation and release

Project 3

More detailed process **activities** (with assessment criteria fit for a presumption of conformity) to address the vulnerability management requirements

During risk assessment the appropriate security controls and their appropriate level can be selected to ensure risks are mitigated to an acceptable level

Risk assessment

Product requirements

Project 2

A mapping of the essential product requirements to a list of appropriate **security controls** at various levels

(controls have their own scale/levels to achieve the goal of the security control)

During the elicit requirements activity the deliverables from project 2 can be used to determine and select the appropriate security controls that should be implemented into the product to fulfil on a risk-based manor the essential requirements

CEN/CENELEC WP – actual status

- PT1 and Vocabulary are submitted to the CCMC for review
  - After that phase they will go in public inquiry
  - The vocabulary (PT4) contains only 16 definitions
    - They excluded the terms already defined in the CRA
    - They re-used the definitions from ISO wherever possible
    - Successful cybersecurity for digital products depends on a shared understanding of key concepts.
    - This document creates that common language, ensuring consistency across the associated European standards
  - PT1
    - Defines core cybersecurity principles to be used across the entire product lifecycle
    - Mandates requirements for assessing and managing cybersecurity risks
    - Outlines necessary activities to ensure an appropriate cybersecurity level at every product phase
    - Offers guidance and elements for product-specific standards, promoting a unified approach.

PT1 - JT013089

- Cybersecurity Principles
  - Risk-Based approach for cybersecurity
  - Security by Design
  - Secure by Default
  - Transparency
  - All these chapters are having two subchapters – Principle and Guidance
- Product cybersecurity risk management elements
  - Product Context (product's use, product's functions, Product's operational environment, Product's system overview, Product's support period)
  - Applicability analysis
  - Product's cybersecurity risks acceptance criteria
  - Consultation on product's cybersecurity risks
  - Assessment of product cybersecurity risk (identification of product assets, identification of product cybersecurity threats, Determination of product's cybersecurity risks, Evaluation of product cybersecurity risks)
  - Treatment of product's cybersecurity risks
  - Communication of product's cybersecurity risks
  - Review of product's cybersecurity risks
- Product cybersecurity activities
  - Product cybersecurity plan
  - Cybersecurity risk management activities
  - Cybersecurity requirements
  - Secure Product Architecture and Design
  - Secure implementation
  - Security verification and validation
  - Secure production
  - Cybersecurity issue management
  - Product monitoring
  - Decommissioning
  - Third-Party Component Cybersecurity Management (incl. Due Diligence part)

PT1 - JT013089 – due diligence

- Needed to the product context that will represent the starting point for the assessment and treatment of risks (this will be an iterative task as updates to the product during its lifecycle can cause the context to change).
- The cybersecurity architecture and design must ensure that the integration of third-party components is performed with due diligence.
- When a product includes any third-party components (or remote data processing services, RDPS), this rigorous due diligence must be applied to all components—whether they're from a third party or not—and to the entire integration process itself.
- Secure implementation
  - In order to manage dependencies and third-party libraries, select secure components and keeping them up to date. Follow the due diligence for that selection.
- Third-Party Component Cybersecurity Management
  - Third-party components introduce significant cybersecurity risks because a vulnerability in one component can compromise the security and integrity of the entire final product.
  - Therefore, due diligence is mandatory when selecting and integrating these elements.

PT1 - JT013089 – due diligence

- This management process specifies the required activities to ensure risks are handled correctly.
- Key tasks include:
  - Selection and Assessment:
    - Verify Intent: Ensure the component's intended use aligns with how it will be integrated into your product.
    - Check Compliance: Evaluate if the component meets applicable legal and contractual requirements, especially cybersecurity standards. This involves checking for a CE marking, evidence of cybersecurity by design, and compliance with vulnerability databases (like the European database).
    - Patching and Support: Confirm the availability of regular cybersecurity patches and a solid vulnerability disclosure process. Critically, consider the support period to avoid risks from obsolete technology.
  - Integration and Risk Handling:
    - Risk Assessment: Formally assess the risk posed by the third-party component and its integration as part of the overall product risk assessment.
    - Secure Integration: Incorporate the component securely following established procedures.
  - Post-Integration and Lifecycle Management:
    - Monitoring: Continuously monitor the component for new vulnerabilities throughout the product's entire lifecycle.
    - Communication: Communicate any newly found vulnerabilities, and potential solutions, to the product user.

Promoting Collective Security

- To improve overall cybersecurity, it's essential to immediately communicate any discovered vulnerabilities to the responsible third-party (supplier, open-source steward, etc.).
- Manufacturers should also consider sharing any developed fixes for those vulnerabilities with the supplier to support transparency and collective security improvement.

PT1 - JT013089 – due diligence

- The entire process of using third-party components must adhere to due diligence and be thoroughly documented.

Phase	Action Required
Selection	The choice of components must be justified and documented upfront.
Assessment	Components and their integration must be included in the product's overall risk assessment and subsequent treatment activities.
Implementation	Components must be securely implemented and integrated into the product design.
Transparency	All third-party software components must be listed in the Software Bill of Materials (SBOM) to manage dependencies.
Verification	Components and their integration must be validated and verified (tested) to ensure they work securely as intended.
Lifecycle	Components must be monitored throughout the entire product lifecycle to identify new vulnerabilities.
Vulnerability Handling	Discovered vulnerabilities must be documented, immediately disclosed to the relevant third-party entity, and remediated following established procedures.

PT2 - JT013091

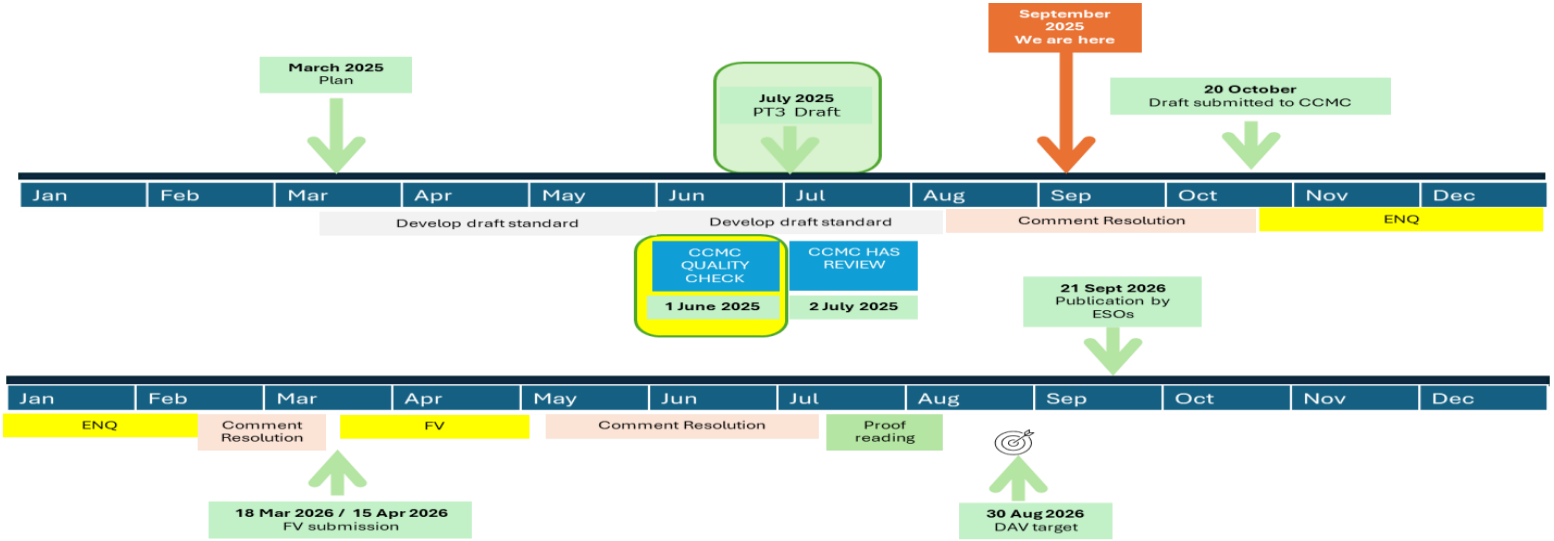
- On hold -> All the meetings are cancelled until 20 October
  - Focus on PT3
- Rely on EN 18031, IEC62443 and NIST SP800-53
  - Gap analysis
  - Mapping on PT2 requirements
- Structure – Requirements catalogue
  - Vulnerability management
  - Security by default
  - Secure SW-update
  - Secure storage
  - Secure communication mechanism
  - Logging mechanism
  - Authentication mechanism
  - Access control
  - User notification mechanism
  - Confidentiality
  - Integrity
  - Data minimization
  - Recovery from incidents
  - External impact limitation
  - Attack surface reduction
  - Reduction of the impact of an incident
  - Recording and monitoring of security activities
  - Deletion mechanism

  + Recommendations for additional requirements

Madalin & David will work on some comments for that one in the next days

PT3 - JT013090

- The commission is still considering the full presumption of conformity on the scope of the PT3 if we address the comments of the Harmonized Standards consultant. The partial presumption is still an option.
- EC assessed and provided comments for PT3



PT3

- Based on
  - EN ISO/IEC 29147:2020 Information technology - Security techniques - Vulnerability disclosure (ISO/IEC 29147:2018)
  - EN ISO/IEC 30111:2020 Information technology - Security techniques - Vulnerability handling processes (ISO/IEC 30111:2019)
  - **PT1** JT013089:2026 Cybersecurity requirements for products with digital elements – Principles for cyber resilience
  - https://www.first.org/global/sigs/vulnerability-coordination/multiparty/guidelines-v1-1
  - Multiple phases
    - Gap Analysis
    - Mapping on PT3 (and on others as well, if relevant)
    - Adopt (as it is or enhanced)
    - There is also the possibility to trigger updates on ISO/IEC standards

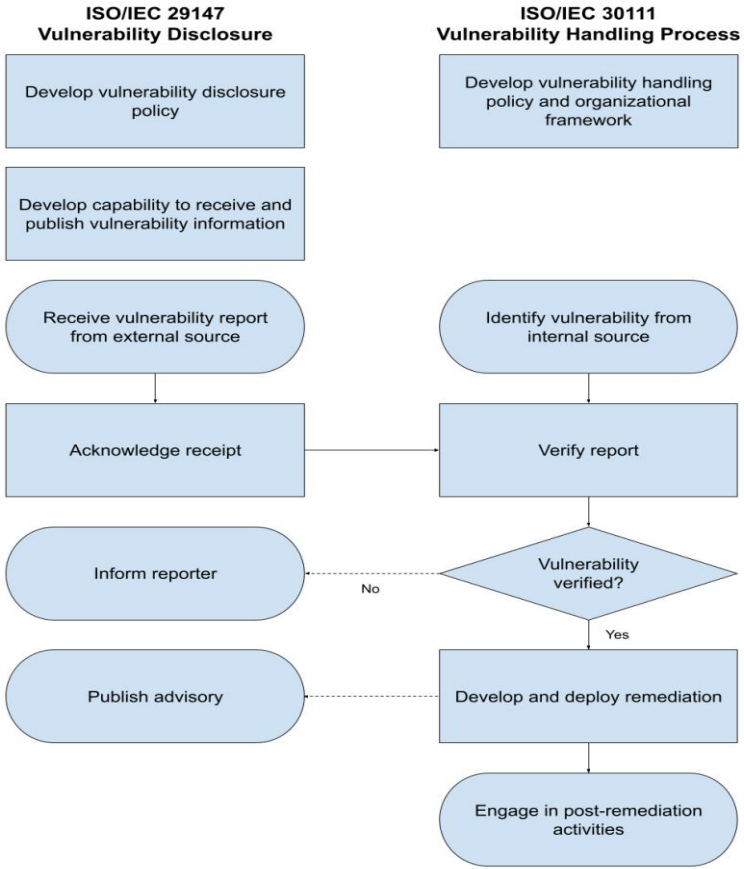


Figure 1 – Relationship between ISO/IEC 29147 and ISO/IEC 30111

PT3

- Structure = Vulnerability Handling Requirements
  - **Preparation** (Policy on coordinated vulnerability disclosure, Capability to receive reports, Contact Information, Secure communication, Product identification, Software components, Hardware components, SBOM)
  - **Receipt** = the discovery phase of the vulnerabilities handling process (Monitoring, Potentially impacted software components, Potentially impacted hardware components)
  - **Verification** = the task to verify an information about a possible vulnerability related to its completeness and technical merit (report verification, triage, Vulnerability Risk Assessment, On-going communication, Coordinator involvement, Operational security)
  - **Remediation** (Remediation Decision, Remediation Development, Remediation Test)
  - **Release** (Provisioning of Security Updates, Distribution of security updates, Release Information
  - **Post release** (Post release plan)

PT3

- David, CRob and Madalin worked on some initial comments
  - The comments were closed on 5 August
  - They are in the phase where they are solving the actual comments
    - We plan to re-submit them in this phase, or if not feasible, during the next phase (Public Inquiry) benefitting also from a wider perspective from our community
- Critical topics
  - Not fully aligned to CRA's requirements for vulnerability management (focus only on Annex I, Part II)
  - Incorporate a lot of ISO content (referenced and not providing all the requirements)
    - and also ignoring many other publicly authoritative documents such as the FIRST PSIRT Services Framework
  - SBOMs minimum elements
    - They want to let the verticals to define the list of minimum set of elements for every vertical
    - There was quite a fight to include a 'unique ID'
    - The document appears to presume that there is a completely-known fully-transitive "list of components" or "identification of hardware and software components" aka SBOMs
  - Misalignment of terms – vendor vs manufacturer
  - Vulnerability Disclosure Policy"(VDP)" vs "Coordinated Vulnerability Disclosure Policy" (CVD)

Standards developed under ETSI

Key information

- https://portal.etsi.org/home.aspx
- All the works are under the control of TC CYBER WG EUSR https://portal.etsi.org/tb.aspx?tbid=919&SubTB=919#/
- The work programme and the meeting schedule can be found navigating on that page
  - Very intense meeting schedule
  - They have monthly joint meetings with CEN and CENELEC
- Their Forge https://forge.etsi.org/rep/cyber/stan4cr2
  - Only 10 standards (among 18) are developed using markdown
  - The links are also displayed on the WI page
- Complementary information resource: https://www.stan4cra.eu/
  - Funding opportunities: https://cyberstand.eu/8th-specific-service-procedure
- Links for Public Consultation on ETSI standards
  - https://docbox.etsi.org/CYBER/EUSR/Open
  - https://labs.etsi.org/rep/stan4cra/

ETSI Public Consultation

- Previewed by a webinar on 29 September
- From late October onwards
  - **Piloting their public consultation at the end of September**
    - https://docbox.etsi.org/CYBER/EUSR/Open
    - https://labs.etsi.org/rep/stan4cra/
    - Pilot standards: Routers, Hypervisors, OS, NI, Boot Managers, Password Managers and Firewalls
    - Everyone will have access to those standards for submitting comments
  - In collaboration with CEN/CENELEC
    - Further details will be provided on Stan4CRA website or ETSI website
      - Specific formal commenting and feedback window
      - Option to comment via ETSI Labs or traditional commenting table
      - Drafts will be available on both ETSI labs and CYBER open portal area
- Standards will be ultimately approved by NSBs
  - Another opportunity to comment via NSB national commenting

ETSI Work Programme

18 WIs, Work in progress, displaying 1 to 18				Displays
Work item number	Version	Current status	Next status	Rapporteur name
CYBER EUSR				
DEN/CYBER-EUS-0010 (EN 304 622) CRA SIEM systemsTopic # 22 Part 1/2	0.0.0	NSB Adoption vote initiated (2025-07-25)	NSB Adoption vote closed	EISMEA Rapporteur
DEN/CYBER-EUS-0011 (EN 304 631) CRA Smart home assistants Topic # 31 full	0.0.1	Early draft (2025-07-09)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0012 (EN 304 626) CRA operating systemsTopic # 26 Part 1/N	0.0.1	Early draft (2025-08-10)	Stable draft	Black Aeva
DEN/CYBER-EUS-0013 (EN 304 627) CRA routers, modems, and switches Topic # 27 Part 1/2	0.0.2	Early draft (2025-08-05)	Stable draft	Banelli Bruno
DEN/CYBER-EUS-0014 (EN 304 632) CRA Smart home security products Topic # 32 full	0.0.1	Early draft (2025-07-09)	Stable draft	Mitterweger Kilian
DEN/CYBER-EUS-0015 (EN 304 624) CRA PKI and digital certificate issuance software - Topic #24	0.0.1	Early draft (2025-06-12)	Stable draft	Haddad Sammy
DEN/CYBER-EUS-0016 (EN 304 635) Essential cybersec reqts for hypervisors and container runtime systems	0.0.1	Early draft (2025-06-18)	Stable draft	Hajj Mohamad
DEN/CYBER-EUS-0017 (EN 304 625) Essential cybersec reqts for physical and virtual network interfaces	0.0.1	Early draft (2025-08-12)	Stable draft	Aurora Valerie
DEN/CYBER-EUS-0018 (EN 304 619) CRA antivirus software Topic # 19 full	0.0.3	Early draft (2025-08-14)	Stable draft	Alemany Pol
DEN/CYBER-EUS-0019 (EN 304 642) Cybersecurity reqts for Network functions of Telecoms systems	0.0.0	NSB Adoption vote initiated (2025-07-23)	NSB Adoption vote closed	Sahlin Bengt
DEN/CYBER-EUS-0020 (EN 304 636) Essential cybersec reqts for firewalls, intrusion detection and prevention systems	0.0.0	NSB Adoption vote initiated (2025-07-25)	NSB Adoption vote closed	Samardzic Damir
DEN/CYBER-EUS-003 (EN 304 634) CRA Personal wearables Topic # 34 full scope	0.0.1	Early draft (2025-07-09)	Stable draft	Pratone Davide
DEN/CYBER-EUS-004 (EN 304 633) CRA Internet connected toys Topic # 33 full scope	0.0.1	Early draft (2025-07-09)	Stable draft	Meister Gisela
DEN/CYBER-EUS-005 (EN 304 620) CRA VPNs Topic # 20 Part 1/2	0.0.3	Early draft (2025-08-08)	Stable draft	Braun Aki
DEN/CYBER-EUS-006 (EN 304 617) CRA essential cyber reqts for browsers Topic # 17	0.0.1	Early draft (2025-08-12)	Stable draft	Thompson-Yvetot Daniel
DEN/CYBER-EUS-007 (EN 304 618) CRA password managers Topic # 18 full	0.0.1	Early draft (2025-08-12)	Stable draft	Thompson-Yvetot Daniel
DEN/CYBER-EUS-008 (EN 304 623) CRA boot managersTopic # 23 Full	0.0.0	Start of work (2025-06-15)	Early draft	Horchert Christian
DEN/CYBER-EUS-009 (EN 304 621) CRA Network Management Topic # 21	0.0.1	Early draft (2025-08-18)	Stable draft	Toikka Santeri

ETSI Work Programme
DEN/CYBER-EUS-003

Timeline	
Work item adoption	1 May 2025
Early draft	9 July 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for personal wearable **products to be worn or placed on a human body that have a health monitoring** (such as tracking) purpose and to which Regulation (EU) 2017/745 or Regulation (EU) 2017/746 do not apply; Or **personal wearable products that are intended for the use by and for children**
- CRA Personal wearables Topic # 34 full scope
- Draft version – 0.0.1
- Structure
  - Product Context (Intended purpose, essential functionalities, architecture, operational environment)
  - Requirements specifications
    - Product's environmental profile
    - Product's technical requirements specifications (KEV, default configuration, authentication, integrity protection, confidentiality protection, data minimization, availability protection, impact minimization, limit attack surface, logging and monitoring mechanisms, deletion mechanisms)
    - Activities' environmental profile
    - Activities' requirements specifications related to the product
  - Assessing for compliance with requirements

ETSI Work Programme
DEN/CYBER-EUS-004

Timeline	
Work item adoption	1 May 2025
Early draft	9 July 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **Internet connected toys** covered by Directive 2009/48/EC that have social interactive features (e.g. speaking or filming) or that have location tracking features
- CRA Internet connected toys Topic # 33 full scope
- Draft version – 0.0.1
- Structure
  - Same as in the case of EUS-003

ETSI Work Programme
DEN/CYBER-EUS-005

Timeline	
Work item adoption	14 July 2025
Early draft	8 August 2025
Final draft	31 January 2025
Publication	11 December 2026

- Title: Essential cybersecurity requirements for **Virtual Private Networks (VPNs)**
- CRA VPNs Topic # 20 Part ½
- Draft version 0.0.10
- Structure
  - Product overview and architecture
  - Actors in the VPN architecture
  - Use-cases and users
  - Risk factors
  - Security profiles
  - Essential functions
  - Physical environment
  - Digital environment
  - Requirements specifications (PT2, RED, Known Exploitable Vuln)

ETSI Work Programme
DEN/CYBER-EUS-006

Timeline	
Work item adoption	14 July 2025
Early draft	8 August 2025
Final draft	31 January 2026
Publication	11 December 2026

- Title: Essential cybersecurity requirements for **browsers**
- CRA essential cyber reqts for browsers Topic # 17
- Draft version 0.0.2
- Structure - Product context
  - Difference between standalone and embedded browsers
  - Use-cases
  - Product overview and architecture
  - Browser specific risk factors
  - Essential functions
  - Operational environment
  - Users

ETSI Work Programme
DEN/CYBER-EUS-007

Timeline	
Work item adoption	19 June 2025
Early draft	(expected) 15 July 2025
Final draft	31 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **password managers**
- CRA password managers Topic # 18 full
- Draft version 0.0.2
- Structure
  - Definition of terms, symbols and abbreviations
  - Compliant products
    - Scope boundaries
    - Product characterization and taxonomy
    - Use cases
    - Product overview and architecture
    - Password manager security requirements

ETSI Work Programme
DEN/CYBER-EUS-008

Timeline	
Work item adoption	19 June 2025
Early draft	(expected) 15 July 2025
Final draft	31 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **boot managers**
- CRA boot managers Topic # 23 Full
- Draft version 0.0.3
- Structure
  - Product context
    - General
    - Product overview
    - Architecture
      - Functional architecture
      - Functional extensions
      - Boot manager capabilities
      - Trust boundaries
      - Resource constraints
      - interfaces
    - Users
    - Use-cases
    - Threat considerations
  - Requirements
    - Applicable requirements
    - Technical requirements
      - Known exploitable vulnerabilities
      - Authentication and access control mechanisms
      - Integrity protection
      - Confidentiality protection
      - Data minimization
      - Availability protection
      - Impact minimization
      - Security by design
      - Secure by default configuration
      - Limit attack surface
      - Logging and monitoring mechanisms
      - Deletion mechanisms
      - Other product's technical requirements specifications
  - Security profiles
    - Base, verified, measured, update, immutable, network, portable, hardware, config, etc.

ETSI Work Programme
DEN/CYBER-EUS-009

Timeline	
Work item adoption	7 May 2025
Early draft	18 August 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **Network Management Systems**
- CRA Network Management Topic # 21
- Draft version 0.0.4
- Structure
  - Definition of terms, symbols and abbreviations
  - Product context
    - Out of scope use/environments
    - Product overview and architecture
    - Use cases
    - Risk factors
    - Security profiles
    - Essential functions
    - Operational Environment
    - Users
    - Distribution of security functions
  - Requirements specifications
  - Security Profiles

ETSI Work Programme
DEN/CYBER-EUS-010

Timeline	
Work item adoption	22 August 2025
Early draft	15 September 2025
Final draft	31 January 2026
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **Security information and event management (SIEM)** systems
- CRA SIEM systems Topic # 22 Part 1/2
- Draft version 0.0.1
- Structure
  - Definition of terms, symbols and abbreviations
  - Product context
    - Out of scope use
    - Product overview and architecture
    - Use-cases
    - Risk factors
    - Security profiles
    - Essential functions
    - Operational environments
    - Users
    - Distribution of security functions
  - Requirements specifications

ETSI Work Programme
DEN/CYBER-EUS-011

Timeline	
Work item adoption	1 May 2025
Early draft	9 July 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **smart home general purpose virtual assistants**
- CRA Smart home assistants Topic # 31 full
- Draft version 0.0.1
- Structure
  - Product context
    - General
    - Intended purpose and reasonably foreseeable use
    - Essential functionalities
    - Architecture
    - Operational Environment
    - Users
  - Requirements specifications
    - Product's environmental profile
    - Product's technical requirements specifications
      - Known exploitable vulnerabilities
      - Default configuration
      - Authentication and access control mechanisms
      - Integrity protection
      - Confidentiality protection
      - Data minimization
      - Availability protection
      - Impact minimization
      - Limit attack surface
      - Logging and monitoring mechanisms
      - Deletion mechanisms
      - Other product's technical requirements specifications
    - Activities' environmental profile
    - Activities' requirements specifications related to the product

ETSI Work Programme
DEN/CYBER-EUS-012

Timeline	
Work item adoption	1 May 2025
Early draft	10 August 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **operating systems**
- CRA operating systems Topic # 26 Part 1/N
- Draft version 0.0.6
- They have completed the first mapping of a technical requirement from end-to-end, connecting use case to the appropriate risk mitigations via risk factors and showing which CRA essential requirements the technical requirement satisfies
- Updates
  - The meetings are oriented towards the existing contributions done in Forge
  - Handling: PC OS, mobile phone OS, server OS, RTOS, embedded OS, etc.
    - Elements included: kernel, device drivers, libraries, authentication services, logging and monitoring, configuration of security-related things, etc.
    - Not included: hypervisors, containers, boot loaders, hardware, etc.
  - Chapters
    - Products overview and architecture (incl. OS security functions, HL OS architectures, access and control mechanisms, scheduling and resource mgmt.)
    - Use-cases to assist manufacturers in choosing the security levels and risk factors
    - Risk factors and tolerance
    - Requirements specifications
    - Security profiles

ETSI Work Programme
DEN/CYBER-EUS-013

Timeline	
Work item adoption	1 May 2025
Early draft	29 July 2025
Final draft	30 December 2025
Publication	11 November 2026

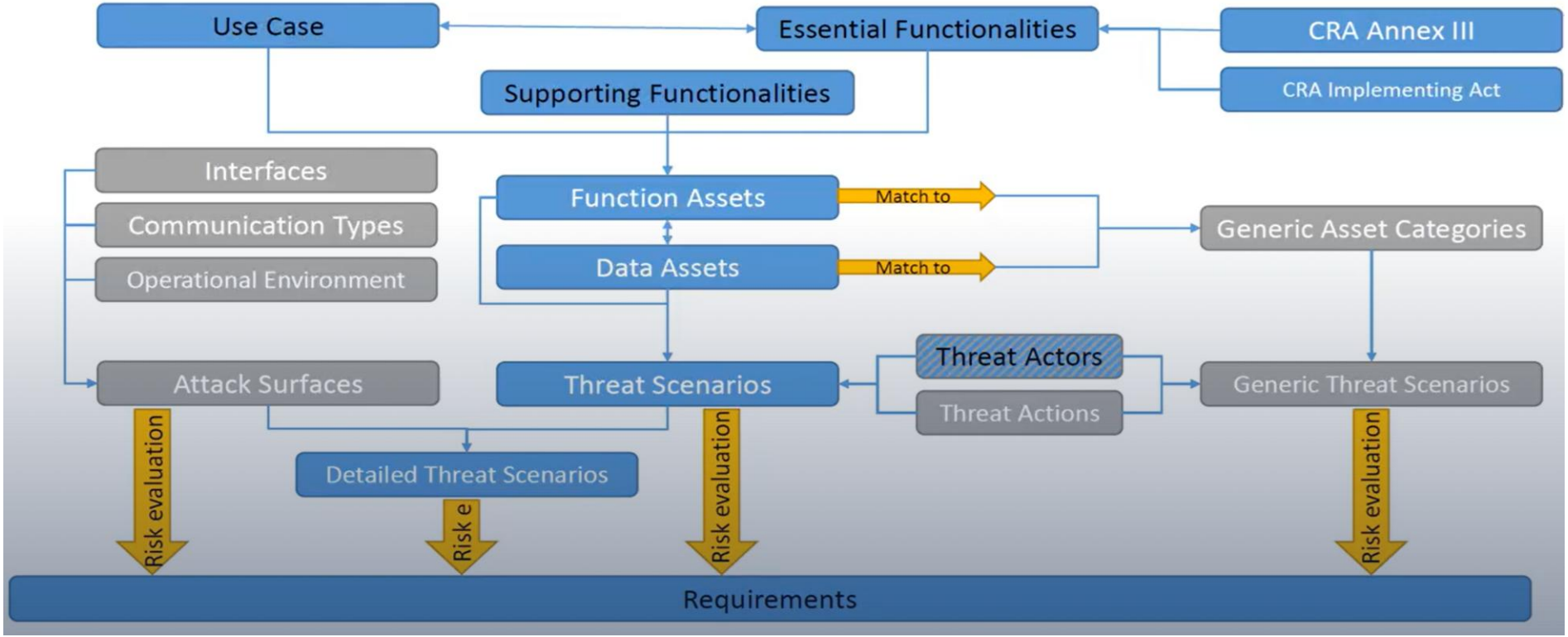
- Title: Essential cybersecurity requirements for **routers, modems intended for the connection to the internet, and switches**
- CRA routers, modems, and switches Topic # 27 Part 1/2
- **Stable** Draft version 0.0.7
- Presented as **100% complete**
- Updates
  - Already a 59-pages document
  - Description of the products and the context
  - A capability model based on the products' way of working
  - Cybersecurity requirements (secure by design – referencing PT1 from CEN/CENELEC, no known vulnerabilities, secure by default configuration, security updates, etc.)
  - Vulnerability handling (based on CEN/CENELEC PT3)

ETSI Work Programme
DEN/CYBER-EUS-014

Timeline	
Work item adoption	1 May 2025
Early draft	9 July 2025
Final draft	31 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **smart home products with security functionalities**; including smart door locks, security cameras, baby monitoring systems and alarm systems
- CRA Smart home security products Topic # 32 full
- Draft version 0.0.1
- Structure
  - The same format as EUS-011

Overview on ETSI CIoT CRA Standards methodology



ETSI Work Programme
DEN/CYBER-EUS-015

Timeline	
Work item adoption	7 July 2025
Early draft	12 July 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **Public key infrastructure** and **digital certificate issuance** software
- CRA PKI and digital certificate issuance software - Topic #24
- Draft version 0.0.2
- Structure
  - Definition of terms, symbols and abbreviations
  - Product contexts
    - PKI products
    - Out of scope use/environments
    - Product overview and architecture
  - Security Profiles
    - Private PKI for SME
    - Large enterprise and public PKI
    - C-ITS PKI

ETSI Work Programme
DEN/CYBER-EUS-016

Timeline	
Work item adoption	26 May 2025
Early draft	18 June 2025
Final draft	31 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **hypervisors and container runtime systems** that support virtualised execution of operating systems and similar environments
- Essential cybersec reqts for hypervisors and container runtime systems Topic #35
- Draft version 0.0.5
- Structure
  - Definition of terms, symbols and abbreviations
  - Compliant Products
  - Representative Use Cases
  - Security Category Levels and Requirement Selection
  - Security Problem Definition
  - Operational Environment Objectives
  - Generic Security Requirements
  - Instantiated VES Security Requirements
  - Instantiated Container Security Requirements
  - Assurance Security Requirements
  - Conformance Assessment of Requirements

ETSI Work Programme
DEN/CYBER-EUS-017

Timeline	
Work item adoption	30 June 2025
Early draft	12 August 2025
Final draft	31 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **physical and virtual network interfaces**
- Essential cybersec reqts for physical and virtual network interfaces Topic 25 Part a
- Draft version 0.0.5
- Structure
  - Product context (what is in, what not)
  - Product overview and architecture
  - Use cases
  - Risk factors
  - Security levels
  - Operational environment
  - Distribution of security functions
  - Requirements specifications

ETSI Work Programme
DEN/CYBER-EUS-018

Timeline	
Work item adoption	30 June 2025
Early draft	18 July 2025
Final draft	30 December 2025
Publication	11 November 2026

- Title: Essential cybersecurity requirements for **software that searches for, removes, or quarantines malicious software**
- CRA antivirus software Topic # 19 full
- Draft version 0.0.5
- Structure
  - Product context
    - Essential functionalities
    - Security Category Levels
    - Identified Threats
    - Intended purpose and reasonably foreseeable use
    - Architecture
    - Operational Environment
    - Users
    - Potential “Chain of Supply” Interactions with other PwDE
  - Requirements specifications
    - Product’s environmental profile
    - Product’s technical requirements specifications
    - Activities’ environmental profile
    - Activities’ requirements specifications related to the product

ETSI Work Programme
DEN/CYBER-EUS-019

Timeline	
Work item adoption	20 August 2025
Early draft	30 September 2025
Final draft	1 May 2026
Publication	10 February 2027

- Title: Cybersecurity Requirements for **Network Functions of Telecommunications Systems**
- Draft version 0.0.2
- Structure
  - Product context
    - Essential functionalities
    - Intended purpose and reasonably foreseeable use
    - Architecture
    - Operational Environment
    - Users
  - Requirements specifications
    - Product's environmental profile
    - Product's technical requirements specifications
      - Security by design
      - Authentication and access control mechanisms
      - Logging and monitoring mechanisms
      - Vulnerability management
      - Security testing and review
      - Deletion mechanisms
      - Confidentiality and integrity protection
    - Activities' environmental profile
    - Activities' requirements specifications related to the product

ETSI Work Programme
DEN/CYBER-EUS-020

Timeline	
Work item adoption	22 August 2025
Early draft	24 August 2025
Final draft	22 May 2026
Publication	17 March 2027

- Title: Essential cybersecurity requirements for **firewalls**, **intrusion detection and/or prevention systems**
- Draft version 0.0.4
- Structure
  - Product context
    - Firewalls
    - Intrusion detection systems
    - Intrusion prevention systems
    - Product architecture and components
    - Use cases and deployment scenarios
    - Product essential functions
    - Operational environment
    - User categories and access context
    - Product security context summary
  - Applicability model
  - Threat landscape and security considerations
  - Risk assessment framework
  - Cybersecurity requirements
  - Vulnerability Handling Requirements

Other general details

- WG EUSR has finalized their team of leaders
  - Sandra Feliciano – Chair – AI Aestas Insignis
  - Simon Phipps – vice-chair – OSI
  - George Sharkov – vice-chair – SBS aisbl
  - Laure Pourcin – Technical Officer - ETSI
- They progress well – EC is happy with the progress
- They are dependent on the vocabulary works at CEN/CENELEC
  - Avoid discrepancies between the vocabulary and their definitions
- They have an intention to include mappings between the standards and CRA

CRA Expert Group

CRA Expert Group

- Missions
  - to assist the Commission's Directorate-General for Communications Networks, Content and Technology ('DG CONNECT) in the **preparation of policy initiatives** in the field of cybersecurity of products with digital elements;
  - to assist DG CONNECT in the preparation of **delegated acts** related to the cybersecurity of products with digital elements;
  - to establish **cooperation between the Commission and Member States and stakeholders** on questions relating to the implementation of Union legislation, programmes and policies in the field of cybersecurity of products with digital elements;
  - to assist DG CONNECT in the early **preparation of implementing acts** related to the cybersecurity of products with digital elements, before submission to the committee in accordance with Regulation (EU) N°182/2011;
  - to assist DG CONNECT in the development of **guidance documents** aimed at facilitating the implementation and compliance with Union legislation by relevant stakeholders in the area of cybersecurity of products with digital elements;
  - to bring about an **exchange of experience and good practice** in the field of policy of cybersecurity of products with digital elements, including related standardisation, security marks and support measures for micro, small and medium-sized enterprises.
- Commission guidance on the CRA (art. 26)
- OpenSSF is a Member as a Type C Organization

https://ec.europa.eu/transparency/expert-groups-register/screen/expert-groups/consult?lang=en&groupID=3967

CRA Expert Group – relevant works

- Updated description of the categories of important and critical products
  - See the meeting slides from 2 September
  - Exclusion of other categories of products as they are covered by other Regulations
- Risk assessment – CRA article 13
  - Scope of the risk assessment
  - Main elements of the risk assessment
  - Relationship to risk assessment under other Union acts (AI Act, NIS2 coordinated risk assessment, others)
- Open source guidelines
  - Shipping security fixes upstream
  - If a company can be a steward and a manufacturer for different projects
  - If there can be multiple stewards for one project
- Guidelines for MSA and CABs
  - Help the EU Member States to appoint the market surveillance and notifying authorities under the CRA
  - help the Commission to constitute a cooperation group with national authorities (ADCO CRA)
  - Accreditation of CABs and laboratories

https://ec.europa.eu/transparency/expert-groups-register/screen/expert-groups/consult?lang=en&groupID=3967

CRA Expert Group – relevant works

- Interplay between the CRA and other related-works
  - EUCC
    - A potential delegated act to establish the presumption of conformity with the CRA via an EUCC certificate
    - Not about mandating the certification
    - Ensure the consistency with CABs
  - RED
    - There is a possibility to repeal the RED DA on cybersecurity (tbc)
    - CRA -> the only horizontal piece of legislation on product's cybersecurity
    - Consistent approach, alignment needed
- Follow-up closely the standards
  - it reiterated that CRA standards should build on the RED DA standards
  - HS should be reviewed at least 5 years

https://ec.europa.eu/transparency/expert-groups-register/screen/expert-groups/consult?lang=en&groupID=3967

CRA Expert Group – relevant works

- Clarifications on the monetization of FOSS
  - Charging a price
  - Monetization of other services or data
  - Support services
  - Donations
    - Monetization if donations significantly exceed “the costs associated with the design, development and provision of a product with digital elements” (recital 15), including the need to have a fair remuneration.
    - accepting donations without the intention of making a profit should not be considered to be a commercial activity
  - Not for profit entities
    - Not subject to the obligations of manufacturers
    - But such legal entity becomes steward
- Stewards
  - Being a steward for one specific product does not mean that that legal entity is to be a steward for other software that it publishes.
  - A legal entity can be steward for one specific FOSS and a manufacturer for another specific FOSS
  - A legal entity that publishes a free version and a monetized version of the same FOSS, can be steward for the free one and manufacturer for the second one

https://ec.europa.eu/transparency/expert-groups-register/screen/expert-groups/consult?lang=en&groupID=3967

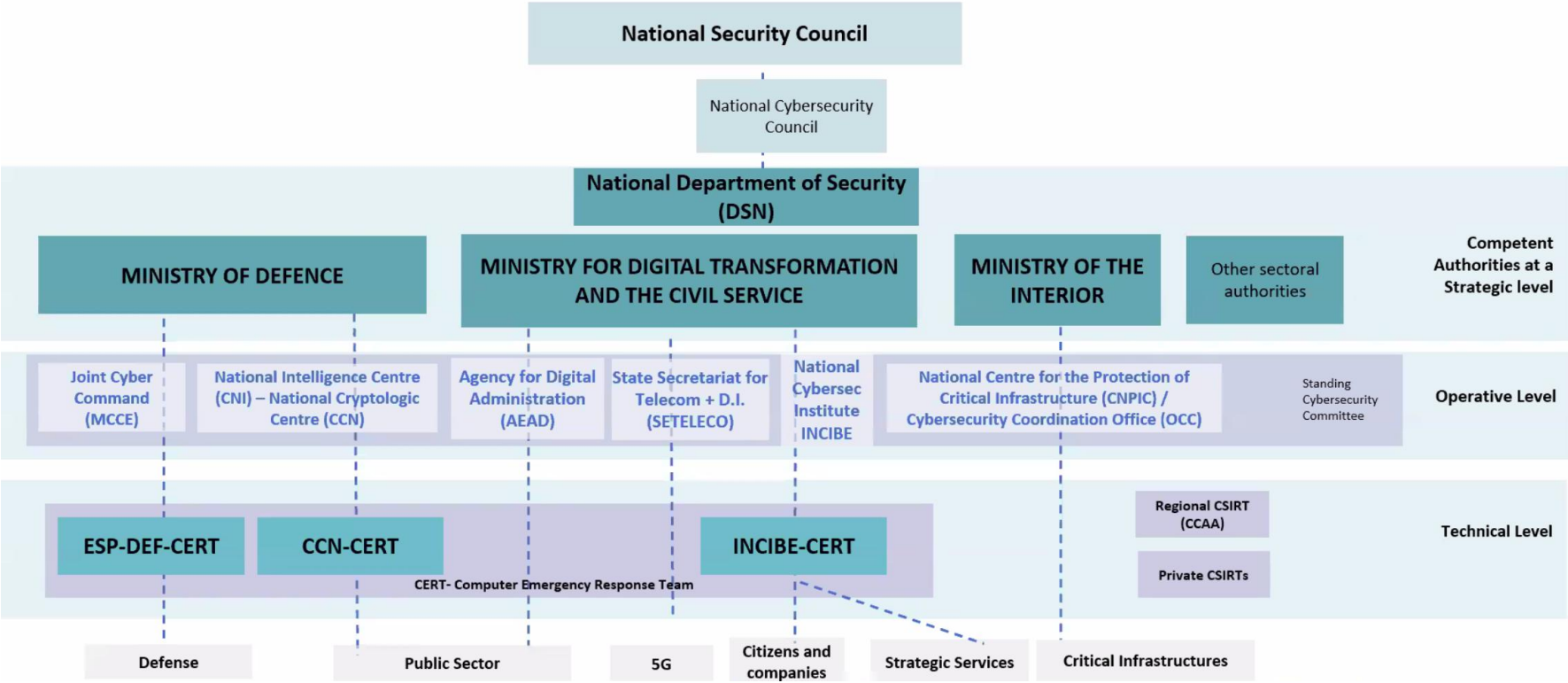
CRA Expert Group – relevant works

- Delegated act on terms and conditions for delaying the dissemination of notifications
  - Under the CRA, manufacturers must report serious security incidents and exploited vulnerabilities on their digital products through a central reporting platform.Crucially, Article 16(2) allows the national CSIRT (the initial coordinator) to postpone the dissemination of this notification to other Member States' CSIRTs. This is an exceptional measure, requiring justified cybersecurity-related grounds, and is intended to manage sensitive situations before wider sharing.
  - To complete the **CRA**, the **Delegated Act** will **lay out the clear conditions** and **terms** that allow for **notifications to be delayed** based on **cybersecurity issues**.
- Support for SMEs

https://ec.europa.eu/transparency/expert-groups-register/screen/expert-groups/consult?lang=en&groupID=3967

AOB

Spanish Cybersecurity Authorities



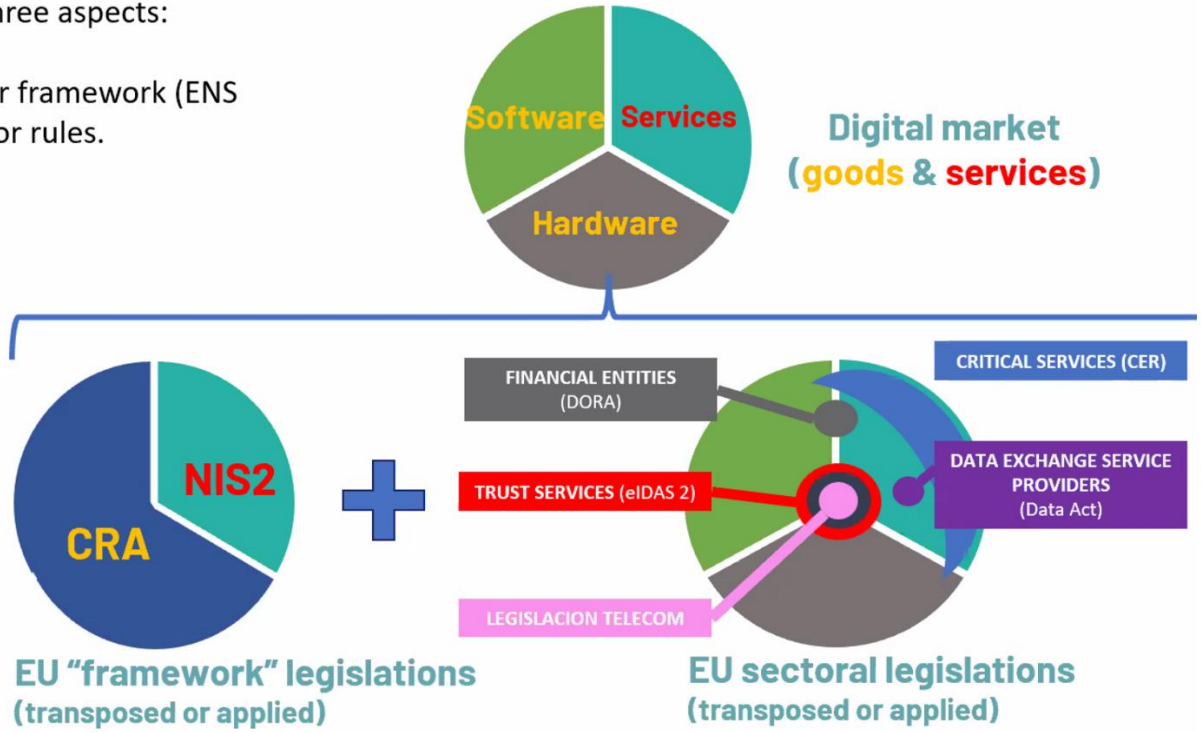
Spanish Regulatory Framework for Cybersecurity

Structured in three aspects:

- Strategy
- public-sector framework (ENS
- private-sector rules.

National Cybersecurity Strategy
Aligned with the EU Cyber Strategy
Part of National Security Strategy.
National Cybersecurity Council.

Esquema Nacional de Seguridad)
Baseline public-sector systems
Mandatory
all public administrations
private contractors & providers
Widely adopted.



Thank you very much

OpenSSF
OPEN SOURCE SECURITY FOUNDATION